

Compliance & Control Crosswalk

NIST CSF 2.0, NIST SP 800-53, ISO/IEC 27001, SOC 2, PCI DSS, GDPR, and COBIT alignment

Program area	NIST CSF 2.0	NIST 800-53 examples	ISO 27001 themes	SOC 2 / PCI / GDPR relevance
Governance & risk	Govern / Identify	PM, RA, PL	Risk management, governance	SOC 2 governance; GDPR accountability
Identity & access	Protect	AC, IA	Access control, authentication	SOC 2 CC6; PCI access; GDPR Art. 32 security
Logging & monitoring	Detect	AU, SI	Logging, monitoring	SOC 2 CC7; PCI logging/monitoring
Incident response	Respond	IR	Incident management	SOC 2 CC7; PCI incident response; GDPR breach process
Recovery	Recover	CP	Business continuity	SOC 2 availability; resilience expectations
Vulnerability mgmt	Identify / Protect	RA, SI, CM	Technical vulnerability mgmt	PCI vulnerability controls; SOC 2 risk mitigation
Data protection	Protect	SC, AC, MP	Classification, crypto, transfer	PCI data protection; GDPR security/minimization
Third-party risk	Govern	SR	Supplier relationships	SOC 2 vendor oversight; GDPR processors

Use of the Crosswalk

- This crosswalk demonstrates control alignment and readiness thinking; it is not a formal certification or attestation.
- One implemented control may support multiple frameworks, reducing duplicate effort.
- Evidence should be collected from control operation - configuration, logs, tickets, approvals, tests, and reviews - not only from policy documents.